Análise de tráfego de rede para DFIR: relatório forense

Nov 1, 2026 · @Tribbiani

Resumo

Estudei como funciona a análise de tráfego de rede em DFIR (forense digital e resposta a incidentes), com o objetivo de aprender o método e montar uma linha de base do comportamento da minha rede. Foram 16 capturas entre 25 e 31 de outubro de 2026, feitas com o Wireshark na placa Wi-Fi (sem modo monitor), no Windows 11 com WSL2, e analisadas com o tshark, o Nmap, o Opera GX e scripts em Python. Tudo foi feito na minha própria rede e no meu computador; a varredura de portas foi feita só no meu celular e na minha televisão, com os familiares que moram comigo avisados e de acordo. A captura 16 foi feita por curiosidade pessoal e apagada depois da análise: seu conteúdo não é descrito, e dela aparecem só resultados agregados, usados como controle.

Três achados se sustentam com certeza alta. Primeiro, o tráfego QUIC (transporte sobre UDP) para o dns.google só existe com o Opera GX rodando: foram sete capturas comparadas, mudando uma condição por vez, e as capturas 06 e 07 diferem apenas pelos processos do Opera; a finalidade provável é DNS sobre HTTPS (certeza média). Segundo, abrindo o navegador com o arquivo de chaves TLS (variável SSLKEYLOGFILE), o Wireshark lê em claro o tráfego do próprio navegador: linhas GET, 200 OK, cabeçalhos, user-agent e server. Isso vale só para o meu computador e não intercepta nem altera a conexão, ao contrário de um proxy; sem as chaves, o certificado e o conteúdo do TLS 1.3 ficam cifrados, e só o SNI (o nome do servidor, em texto aberto), os IPs, as portas, os tempos e os tamanhos continuam visíveis. Terceiro, uma varredura de portas se reconhece por contagem: 1.000 portas distintas em 1,17 s, da mesma origem; um script de janela deslizante detectou isso, e a navegação normal (captura 16) não disparou o alerta. Com certeza média, a impressão JA4 mostra a família do software (a do Opera é igual nas capturas 08 e 16, e Opera e Spotify compartilham o hash de cifras por usarem o motor Chromium), mas não o aplicativo exato.

Ficaram em aberto: o aparelho .34, que mandou centenas de respostas ARP sem ninguém perguntar (141 em 35 s na captura 09 e 453 na 10); alguns aparelhos sem dono, que eu teria que conferir um por um com os donos e que não afetaram os achados acima; quem fala com a telemetria da Microsoft; e o serviço real de cada porta aberta da TV, que o Nmap só adivinhou pelo número (a detecção de versão, -sV, resolveria). A seção Casos em aberto

traz os outros limites. Com a linha de base, a varredura de portas e a janela de detecção em mãos, o próximo passo é uma análise de incidente: um script inofensivo, só local, que imita o comportamento de um malware e permite comparar a rede com a linha de base.

Escopo, autorização e limites

O estudo cobre apenas a minha rede doméstica e os meus aparelhos, e este relatório não traz tráfego de terceiros.

- **O que foi capturado:** o tráfego do meu computador, mais o que a rede anuncia a todos (ARP, mDNS, SSDP). Com a placa Wi-Fi em modo comum, o computador não recebe os pacotes dirigidos a outros aparelhos.
- **Varreduras:** a descoberta de aparelhos (ARP) consultou todos os endereços da sub-rede. A varredura de portas foi feita só em dois aparelhos meus: o iPhone e a TV do meu quarto.
- **Autorização:** a rede é da família e todos foram avisados e autorizaram a análise.
- **Uma captura de estudo (16)** foi apagada depois da análise, e seu conteúdo não é descrito neste relatório.
- **O que não é publicado:** capturas (pcap), arquivos de chaves TLS e CSVs derivados ficam só no meu computador. Os scripts e este relatório podem ser publicados, pois já foram higienizados.

Ambiente e metodologia

Todas as capturas foram feitas com o Wireshark no meu próprio computador, na minha rede doméstica, seguindo uma ficha de captura e conferindo cada arquivo por hash.

- **Ambiente:** Windows 11 com WSL2 (Ubuntu), Wireshark (captura na placa Wi-Fi), tshark, Nmap 7.96, Python (Miniconda) e VS Code. A rede é 192.168.0.0/24, com o roteador em 192.168.0.1.
- **Ficha de captura:** antes de cada captura, anoto os aplicativos abertos (conferidos no Gerenciador de Tarefas, aba Detalhes), o objetivo e o horário. A lição veio da captura 06, em que o Opera GX parecia fechado mas tinha dois processos em segundo plano.
- **Uma variável por vez:** para atribuir um tráfego a um programa, mudo uma condição e repito a captura (caso do dns.google).
- **Integridade:** o SHA-256 de cada captura é calculado com `Get-FileHash` e anotado no diário.
- **Extração e análise:** o tshark exporta só os campos que importam para CSV, e scripts em Python contam e comparam (anexo).

- **Decifrar o próprio tráfego:** o navegador é aberto com a variável `SSLKEYLOGFILE`, e o Wireshark lê o arquivo de chaves. Só funciona para o tráfego do meu computador, e o arquivo de chaves nunca sai dele.

Como indico a certeza

- **Alta:** duas evidências independentes, ou conferido no próprio aparelho.
- **Média:** uma evidência forte, mas com explicação alternativa possível.
- **Baixa:** hipótese ainda não testada.

Escrevo "consulta ao domínio X", e não "acessou o site X", porque o nome no SNI não prova qual programa fez o pedido nem a intenção de quem estava no aparelho.

Linha de base

Num dia comum a rede tem cerca de 12 aparelhos vistos e o meu PC fala com poucos serviços fixos, e é contra isso que cada anomalia foi medida.

O que é normal	Evidência	Certeza
Rede ociosa: ARP, NDP e MLD (IPv6), SSDP e mDNS dos aparelhos se anunciando	Captura 01 (136 pacotes)	alta
DNS comum para a maioria dos sites, com o 8.8.8.8 e o resolvedor da operadora	Capturas 02 a 04	alta
Telemetria da Microsoft (mobile.events.data.microsoft.com), com um cliente do tipo Windows (JA4 t13d201200)	Capturas 03, 05 e 07	média
Tráfego QUIC para dns.google, só quando o Opera GX está rodando	Capturas 01 a 07, com e sem o Opera	alta
Spotify: conexões TCP e QUIC para domínios do próprio Spotify	Capturas 05, 07 e 08	alta
Opera GX: serviços do próprio navegador (atualização, extensões, página inicial) logo ao abrir	Capturas 08 e 16	alta
Aplicativos que costumam estar abertos: Opera GX, Spotify, Claude Code, VS Code e o terminal	Minha rotina; conferida só em parte	média

Pontos da linha de base ainda sem explicação: uma linha 802.1Q (VLAN) que respondia por 23,5% dos quadros da captura 01 e pacotes UDP para a porta 15600 (parece BSDP, não confirmado).

Linha do tempo das capturas

Foram 16 capturas entre 25 e 31 de outubro de 2026, cada uma com uma pergunta e uma condição conhecida; a 16 foi apagada e não é detalhada. As datas das capturas 02 a 07 são aproximadas.

Nº	Quando	Objetivo e condições	Resultado
01	25/10	Rede ociosa	136 pacotes; ARP, NDP, MLD, SSDP e mDNS
02	25 a 27/10	Abrir um site, foco em DNS	23.898 pacotes, 1.116 de DNS; o navegador pergunta HTTPS (tipo 65), AAAA e A ao mesmo tempo
03	25 a 27/10	nslookup no 8.8.8.8 e na operadora, navegador aberto	7.626 pacotes; o nslookup faz perguntas extras (PTR e sufixo .lan); o TTL do mesmo registro varia
04	25 a 27/10	Corrida entre dois resolvedores, 4 rodadas, navegador fechado	490 pacotes; sem vencedor com uma amostra só
05	25 a 27/10	Abrir um site no Opera GX, foco no Client Hello	373 pacotes; certificado invisível (TLS 1.3); QUIC para dns.google
06	27/10	Só o Spotify (mas o Opera GX tinha 2 processos escondidos)	Captura contaminada; lição de método
07	27/10	Só o Spotify, processos conferidos	1.550 pacotes; sem tráfego para dns.google
08	27/10	Visita com arquivo de chaves TLS ativo	Tráfego decifrado (HTTP/1.1, 2 e 3); servidor atrás da Cloudflare
09	29/10 10:40	Nmap de descoberta (ARP), padrão	O Nmap listou 4 aparelhos; a captura mostrou respostas atrasadas de outros
10	29/10 11:01	Nmap de descoberta, modo paciente (-T2)	6 aparelhos em 305 s

Nº	Quando	Objetivo e condições	Resultado
11	29/10 11:35	3 portas no iPhone	2 fechadas, 1 aberta (62078)
12	29/10 13:35	Portas 1 a 1000 no iPhone	1.000 SYN em 1,17 s e 1.000 RST; nenhuma aberta
13	31/10 16:17	Portas 1 a 1000 na TV do quarto	Igual ao iPhone: nenhuma aberta
14	31/10 16:25	Todas as portas da TV	14 portas abertas
15	31/10	Só o VS Code aberto	A telemetria da Microsoft apareceu com 3 impressões JA4 diferentes
16	31/10 18:22	Estudo de uma visita (apagada)	140 Client Hello; impressões do Opera reproduzidas; o alerta de varredura não disparou

Achados

Oito achados se sustentam nas capturas; os três mais fortes são o dns.google atribuído ao Opera GX, a decifração do próprio tráfego e a detecção de varredura por contagem de portas.

Achado	Evidência	Certeza	Limites
O tráfego QUIC para dns.google só existe com o Opera GX rodando	Sete capturas comparadas, mudando uma condição por vez; a 06 e a 07 diferem só pelos processos do Opera	alta	A finalidade (provavelmente DNS sobre HTTPS) é média; a opção de DoH do Opera está desligada e o mecanismo é desconhecido; as condições das capturas 02 e 03 foram anotadas de memória, e a prova mais forte é o par 06 e 07

Achado	Evidência	Certeza	Limites
Com o arquivo de chaves, o tráfego do próprio navegador é lido em claro	Captura 08: linhas GET, 200 OK e HEADERS; user-agent OPR/137; server: cloudflare	alta	Só vale para o meu computador e exige o arquivo de chaves; o user-agent é uma etiqueta que pode ser falsificada
No TLS 1.3 o certificado e o conteúdo ficam cifrados; o SNI, os IPs, as portas, os tempos e os tamanhos continuam visíveis	Capturas 05 e 16: 0 mensagens Certificate; SNI em texto aberto	alta	O SNI mostra o destino, não o programa nem o que foi feito no site
O endereço Wi-Fi do iPhone muda: .107 (25/10) e .17 (29/10)	Endereço conferido nas configurações do celular	alta para o .17; média para serem o mesmo aparelho	Endereço privado rotativo; o MAC não é identificador estável, então cada registro leva a data
A descoberta ativa acha mais que a escuta, mas não acha tudo	Capturas 09 e 10: respostas ARP chegaram 5 a 15 s depois, quando o Nmap já tinha desistido; o modo paciente achou 6, não 4	média	Explicação por economia de energia dos aparelhos é hipótese; aparelhos entram e saem da rede
Portas abertas: o iPhone tem 1 (62078) e a TV do quarto tem 14, nenhuma abaixo de 1000	Capturas 11 a 14, com SYN/ACK nas portas abertas e RST nas fechadas	alta	O nome do serviço vem de uma tabela por número de porta e é só palpite (baixa); "aberta" não quer dizer perigosa

Achado	Evidência	Certeza	Limites
Uma varredura de 1.000 portas se reconhece por contagem: 1.000 portas distintas em 1,17 s, da mesma origem e com a mesma porta de origem	Capturas 12 e 13; script de janela deslizante; controle negativo na captura 16 (navegar normalmente usa 1 porta por destino)	alta	Um scan lento escapa de uma janela curta; varredura é reconhecimento, não prova de invasão
O mesmo programa mantém a impressão JA4 entre capturas, mas o JA4 só mostra a família do software	JA4 do Opera igual nas capturas 08 e 16; Opera e Spotify compartilham o hash de cifras (motor Chromium)	média	Pode ser imitado; não separa programas com o mesmo motor

Casos em aberto e lacunas

Sete perguntas ficaram sem resposta, e cada uma tem um jeito claro de ser fechada.

Caso	O que se sabe	Como fechar
Quem fala com a telemetria da Microsoft	Pelo menos 4 famílias de cliente chegaram ao mesmo servidor (capturas 03 a 15). O VS Code não reproduziu a impressão da captura 08; o Spotify é candidato fraco	Capturas isoladas com um programa por vez, reiniciando o programa dentro da captura e conferindo os processos
Por que o aparelho .34 manda centenas de respostas ARP sem ninguém perguntar	141 em 35 s na captura 09 e 453 na 10; conteúdo coerente com o próprio MAC	Identificar o aparelho (ipconfig /all) e capturar com ele desligado
Aparelhos sem dono: .74 (Samsung), .170 (Apple), .222 e .242 (MAC aleatório)	Responderam em algumas varreduras ou só aparecem no arp -a	Conferir o endereço Wi-Fi nos aparelhos e a lista do roteador, com autorização
Conexão do meu PC com a outra TV (.152) nas portas 7678 e 8080	Conexão normal, com dados, que não veio do Nmap	Seguir o fluxo TCP e achar o programa de origem

Caso	O que se sabe	Como fechar
Mecanismo do tráfego para dns.google no Opera GX	Depende do Opera rodando; a opção de DoH está desligada	Capturar com chaves e comparar a abertura do Opera com e sem componentes
Serviço real de cada porta aberta da TV	O Nmap só adivinhou pelo número	Rodar a detecção de versão (-sV) só nos meus aparelhos
Linha 802.1Q (23,5% da captura 01) e UDP na porta 15600	Vistas na captura ociosa	Abrir os pacotes e ler os cabeçalhos

Conclusões e lições de método

- **A captura prova fatos do tráfego, não intenção nem ato ilícito.** Por isso escrevo "consulta ao domínio X", e não "acessou o site X": o nome no SNI não prova qual programa fez o pedido nem o que a pessoa fez lá.
- **Uma variável por vez e ficha de captura.** A captura 06 parecia ter só o Spotify, mas o Opera GX tinha dois processos escondidos; só a 07, com os processos conferidos, permitiu concluir.
- **Condição anotada de memória não é condição verificada.** As condições das capturas 02 e 03 foram anotadas sem conferência; por isso a prova mais forte sobre o dns.google é o par 06 e 07.
- **Linha de base e controle negativo antes de chamar algo de anomalia.** O alerta de varredura só tem valor porque a navegação normal (cerca de 1 porta por destino) não o dispara.
- **A criptografia limita o que se vê, e a chave muda isso só no próprio computador.** No TLS 1.3 o certificado e o conteúdo são cifrados; o SNI, os IPs, as portas, os tempos e os tamanhos continuam visíveis e já dizem muito.
- **Endereço MAC rotativo não é identificador estável.** O iPhone apareceu com endereços diferentes em dias diferentes; cada registro de aparelho precisa da data.
- **Detectar não é impedir, e varredura não é invasão.** A contagem de portas reconhece o reconhecimento da rede; um scan lento escapa de uma janela curta.
- **Num caso real, o tráfego é uma parte da evidência.** Ele seria cruzado com artefatos do computador (registro, histórico do navegador, dispositivos USB), com cadeia de custódia e hash de cada captura. Capturar o tráfego de outras pessoas exige autorização.

Anexos

Os scripts e os comandos permitem repetir a análise em qualquer captura nova.

A. Scripts em Python

Script	O que faz
contar_portas_v3.py	Procura varredura: conta portas distintas por origem e destino numa janela deslizante (--limite e --janela)
portas_abertas.py	Lista as portas abertas (SYN/ACK) e quantas vezes cada uma respondeu
contar_ja4.py	Agrupa os Client Hello pela impressão JA4 e lista os nomes (SNI) de cada grupo
comparar_ja4.py	Compara as impressões de um nome entre várias capturas

Os scripts leem CSVs exportados pelo tshark, com filtros como `tcp.flags.syn==1 and tcp.flags.ack==0` (varredura) e `tls.handshake.type==1` (Client Hello). Os comandos completos estão no guia `comandos.md`. Limitação: os scripts de SYN e SYN/ACK olham só IPv4.

B. Glossário

- **SNI:** o nome do servidor, enviado em texto aberto no início de uma conexão TLS.
- **JA3 e JA4:** impressão digital de como um programa fala TLS, calculada a partir do Client Hello.
- **SYN, SYN/ACK e RST:** os pacotes do aperto de mão do TCP; porta aberta responde SYN/ACK e porta fechada responde RST.
- **QUIC:** transporte sobre UDP que carrega o HTTP/3 e já inclui o TLS 1.3.
- **TTL:** no IP, o limite de saltos; no DNS, a validade restante da resposta no cache.